UAT Risk Register — IAM Automation Phase 1

These risks are assessed against the approved auditor architecture. A writer capability is a Phase 1 safety risk only when it could be reached accidentally; its business workflow is deferred and must not block Phase 1 acceptance.

Scope classifications: `PHASE1_CORE`, `PHASE1_PLATFORM`, `PHASE2_WRITER`, `FUTURE_INTEGRATION`, and `OUT_OF_SCOPE`.

ID	Scope	Risk	Evidence / trigger	P	I	Score	UAT treatment / owner	Status
UR-001	PHASE1_CORE	Wrong observations are joined or split because identity keys and fallback signals are not approved.	`source_reconciliation.py`; aliases, email/name fallback; Q-001..005	4	5	20	Approve identity evidence matrix; UAT-003/005/018/019; IAM Identity Owner.	Open — business decision
UR-002	PHASE1_CORE	Analytical identity correlation is treated as an authoritative employee creation decision.	Existing `_promote_record`/RSR promotion path; canonical terminology clarification	4	5	20	Test analytical candidate/identity only; block source mutation; IAM Identity Owner.	Open — boundary control
UR-003	PHASE1_PLATFORM	Writer-like routes remain reachable from a read-only deployment.	`ARCHITECTURE.md` versus `admin_routes.py` / `employee_routes.py`	4	5	20	Technical gate/composition boundary; UAT-027; Security Owner.	Open — technical gate
UR-004	PHASE1_CORE	Rehire evidence is classified incorrectly because the 30-day parameters and dates are undefined.	`rehire_alert_service.py`; business calendar; Q-018..023	4	5	20	Detection-only boundary tests; Lifecycle Owner.	Open — business decision
UR-005	PHASE1_CORE	Analytical evidence exports are incomplete or misleading because grain, coverage, eligibility, and finding inclusion are undefined.	`report_service.py`; Q-039..040	4	5	20	Control totals and reproducibility; Reporting Owner.	Open — business decision
UR-006	PHASE1_CORE	A no-hire condition is missed or incorrectly classified as a business action.	REQ-003; no complete finding service	3	5	15	Detect `POLICY_RELEVANT_FINDING` only; Compliance Owner.	Open — incomplete
UR-007	PHASE1_CORE	Duplicate candidates are not surfaced or are overstated due to name-only grouping.	`list_canonical_duplicates`; no fuzzy threshold	3	5	15	Candidate explanation and evidence; Identity Owner.	Open
UR-008	PHASE1_PLATFORM	Role configuration permits data exposure or authoritative mutation.	`role_catalog.py` versus `identity.py`; Q-036/037	3	5	15	Production role matrix and negative access tests; Security Owner.	Open — contradiction
UR-009	PHASE1_PLATFORM	Development auto-approval/local authentication is used in production.	`IAM_DEV_AUTO_APPROVE_USERS`; `identity.py`	3	5	15	Deployment configuration gate; Security/Operations.	Open

ID	Scope	Risk	Evidence / trigger	P	I	Score	UAT treatment / owner	Status
UR-010	PHASE1_CORE	Stale or late-arriving data is classified as current discrepancy without temporal context.	Created/updated/effective/received timestamps differ by service	4	4	16	UAT-014/016; Data Governance Owner.	Open
UR-011	PHASE1_CORE	Missing/conflicting evidence creates false positive volume or remains unresolved.	Quarantine/exception paths; ownership and SLA open	4	4	16	Finding class, owner, SLA, closure evidence; Operations Owner.	Open
UR-012	PHASE1_CORE	Historical identifier/name changes create false analytical splits or erase lineage.	Worker history and identifier model; policy open	3	5	15	UAT-017/018/019; Identity Owner.	Open
UR-013	PHASE1_CORE	Deactivated/reactivated observations are misclassified or included/excluded incorrectly from evidence exports.	Status rank and active fallback; no global lifecycle policy	3	5	15	Evidence-only status tests; Lifecycle/Data Owners.	Open
UR-014	FUTURE_INTEGRATION	Salesforce handoff is mistaken for live provisioning.	Export-only XLSX; no Salesforce API	3	4	12	Keep deferred and label any future handoff; Salesforce Owner.	Deferred
UR-015	FUTURE_INTEGRATION	Hardcoded Salesforce mappings produce misleading future handoff data.	Country, timezone, locale, alias, federation defaults	3	4	12	Validate mappings only when future integration is scoped; Salesforce Owner.	Deferred
UR-016	PHASE1_PLATFORM	Audit evidence cannot prove platform actions or tamper/retention requirements.	JSONL audit; retention/immutability incomplete	3	5	15	Event catalog, retention and assurance criteria; Audit Owner.	Open
UR-017	PHASE1_PLATFORM	Local operational notifications leak across users or are lost during runtime recovery.	`.iam_notifications` local store; policy open	2	4	8	Privacy/backup tests; Security + Operations.	Open
UR-018	PHASE1_PLATFORM	Global snapshot publication signal is duplicated, suppressed, or confused with business-change publication.	Five-minute throttle/shared signal	2	4	8	UAT-035/036; Operations Owner.	Open
UR-019	PHASE1_PLATFORM	Requirements and implementation have no authoritative baseline for platform acceptance.	Tracker has 62 Pending items while docs/tests show foundations	4	3	12	Reconcile scope/status; Product Owner.	Open
UR-020	PHASE1_CORE	Source schema/mapping changes silently alter matching or finding results.	Header aliases and mappings in services/config	3	4	12	Version mappings and regression fixtures; Source Owners.	Open

ID	Scope	Risk	Evidence / trigger	P	I	Score	UAT treatment / owner	Status
UR-021	PHASE1_PLATFORM	Recovery restores a valid but wrong analytical snapshot or loses evidence.	Checksums/backups/restore exist; RPO/RTO open	2	5	10	Version selection and restore evidence; Operations Owner.	Open
UR-022	FUTURE_INTEGRATION	Future connector availability is confused with Phase 1 reconciliation acceptance.	AD/Azure, CXOne, NICE, SQL, orchestrator, ITSM placeholders	3	4	12	Maintain explicit integration boundary; Solution Owner.	Deferred
UR-023	PHASE1_CORE	Source coverage absence is treated as an error before the legitimate latency window expires.	Coverage fields; no population-specific latency policy	4	4	16	UAT-014/016; Data Owner.	Open
UR-024	PHASE1_CORE	A field conflict is silently overwritten or an expected difference becomes an alert.	Selective source update behavior; no finding matrix	3	4	12	Use classification model; Data Governance Owner.	Open
UR-025	PHASE2_WRITER	Future request/approval/apply state semantics are mistaken for Phase 1 finding status.	Request model and publication queue	3	3	9	Keep deferred; no Phase 1 sign-off dependency; Process Owner.	Deferred
UR-026	PHASE1_CORE	Uncontrolled holiday/calendar changes alter potential-rehire detection.	Optional `REHIRE_HOLIDAYS`; invalid entries ignored	2	4	8	Version and test calendar configuration; Operations Owner.	Open

TOP 5 Phase 1 production risks

1. Wrong identity correlation from unapproved matching equivalence or fallback signals (UR-001).
2. Analytical identity resolution being mistaken for authoritative employee creation (UR-002).
3. Accidental authoritative writer capability reachable in a read-only deployment (UR-003).
4. False or missed rehire findings caused by unresolved temporal semantics (UR-004).
5. Incomplete or misleading evidence exports caused by undefined coverage/grain rules (UR-005).

Risk acceptance rule

No risk scored 20 may be accepted by passing a technical test alone. It requires a named business owner, a written analytical interpretation, evidence, and residual-risk acceptance. Phase2 writer and future-integration risks are tracked but do not block Phase 1 unless their presence violates the Phase 1 safety boundary.